

PENETRATION TESTING REPORT

Black-Box Engagement – Mediroza General Hospital

W4-CAPSTONE | CYBERSECURITY | NETWORKWALKS

Prepared By	Suvayan Ghosh – Cybersecurity Analyst
Program / Batch	B083D-Networkwalks
Report Date	03/10/2026
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Full Black-box Penetration Test
Duration	5 Days
Permission Secured	Yes; authorised by Networkwalks Academy for this simulated engagement

CONFIDENTIAL – prepared for Mediroza General Hospital and Networkwalks Academy. Not for external distribution.

1. Liability Disclaimer

This penetration test was performed exclusively against medirozahospital.com, a simulated training environment built and authorised by Networkwalks Academy for this capstone exercise. Mediroza General Hospital is not a real organisation, and no real patient, staff or financial data was involved at any point. All records encountered during testing are synthetic data created for this lab.

Every activity described in this report including the SQL injection authentication bypass, the decryption of the three retrieved PDF files, and the retrieval of the exposed database backup – was performed only against this designated target, within the rules of engagement set out in Section 3, and with written authorisation already granted before testing began.

This report is produced for educational purposes as part of the Cybersecurity & Ethical Hacking Internship at Networkwalks. None of the techniques described here should be used against any system without explicit written permission from its owner. Unauthorised access to a computer system is a criminal offence in most jurisdictions, regardless of intent or outcome.

2. Executive Summary

Between the start and end of this five-day engagement, I carried out a black-box penetration test against medirozahospital.com on behalf of Networkwalks Academy. No credentials, source code or architecture documentation were provided at the outset, only the target domain itself.

Testing uncovered a chain of seven linked weaknesses that, together, allowed complete unauthenticated access to confidential patient lab reports and to an exposed internal database backup containing full staff salary and shareholder records. The most serious issue was a SQL injection vulnerability in the patient portal's login form, which allowed authentication to be bypassed entirely without any valid credentials. On its own, this would already be rated Critical. Combined with the unauthenticated, publicly exposed database backup discovered later in the engagement, the combined risk to Mediroza General Hospital is assessed as Critical, since it directly resulted in the exposure of sensitive personal and financial data for 30 staff members.

In total, this engagement identified 7 findings across the following severities:

Severity	Count
Critical	2
High	2
Medium	2
Low	1

Full technical detail, evidence and remediation guidance for each finding is provided in Sections 4 through 6 of this report.

3. Scope and Methodology

3.1 Engagement Brief

Field	Detail
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Full black-box penetration test
Duration	5 days
Rules of Engagement	Testing limited to the target domain only. No social engineering. No denial of service. No testing outside agreed scope.

3.2 Methodology

Testing followed a black-box methodology with no information supplied beyond the target domain, structured around four milestones: initial access, data extraction, critical data exposure, and reporting. Each milestone was approached only once the previous one had produced a confirmed result – the chain documented in Section 4 reflects the actual order findings were uncovered in, not a reconstruction after the fact.

3.3 Tools & Techniques Used

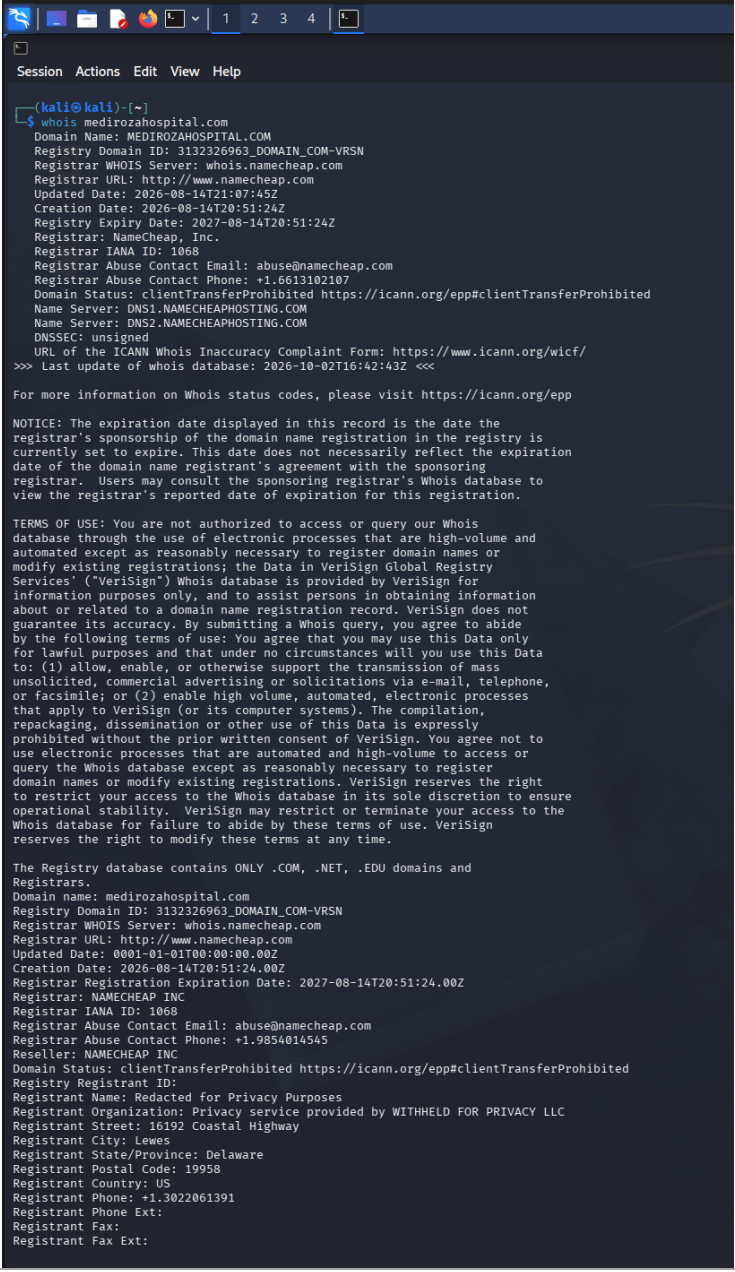
Tool / Technique	Purpose
whois / nslookup	Domain registration and DNS footprinting
nmap	Port scanning to map every service exposed, not just the web application
wafw00f	Identified the WAF sitting in front of the site
curl	Header inspection, path probing, and retrieval of the exposed database backup
Manual SQL Injection	Authentication bypass on the patient portal login
NetworkWalks Hash Calculator & Password Cracker	PDF hash extraction and dictionary-attack cracking
exiftool	PDF metadata inspection

4. Findings and Proof of Exploitation

The following section documents each stage of the engagement in the order it was performed, along with the evidence collected at each step.

4.1 M1 – Initial Access

whois against medirozahospital.com showed a domain registered through NameCheap only weeks before testing began, with registrant details held behind third-party privacy protection.



```
(kali@kali)~$ whois medirozahospital.com
Domain Name: MEDIROZAHOSPITAL.COM
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2026-08-14T21:07:45Z
Creation Date: 2026-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-10-02T16:42:43Z <<<

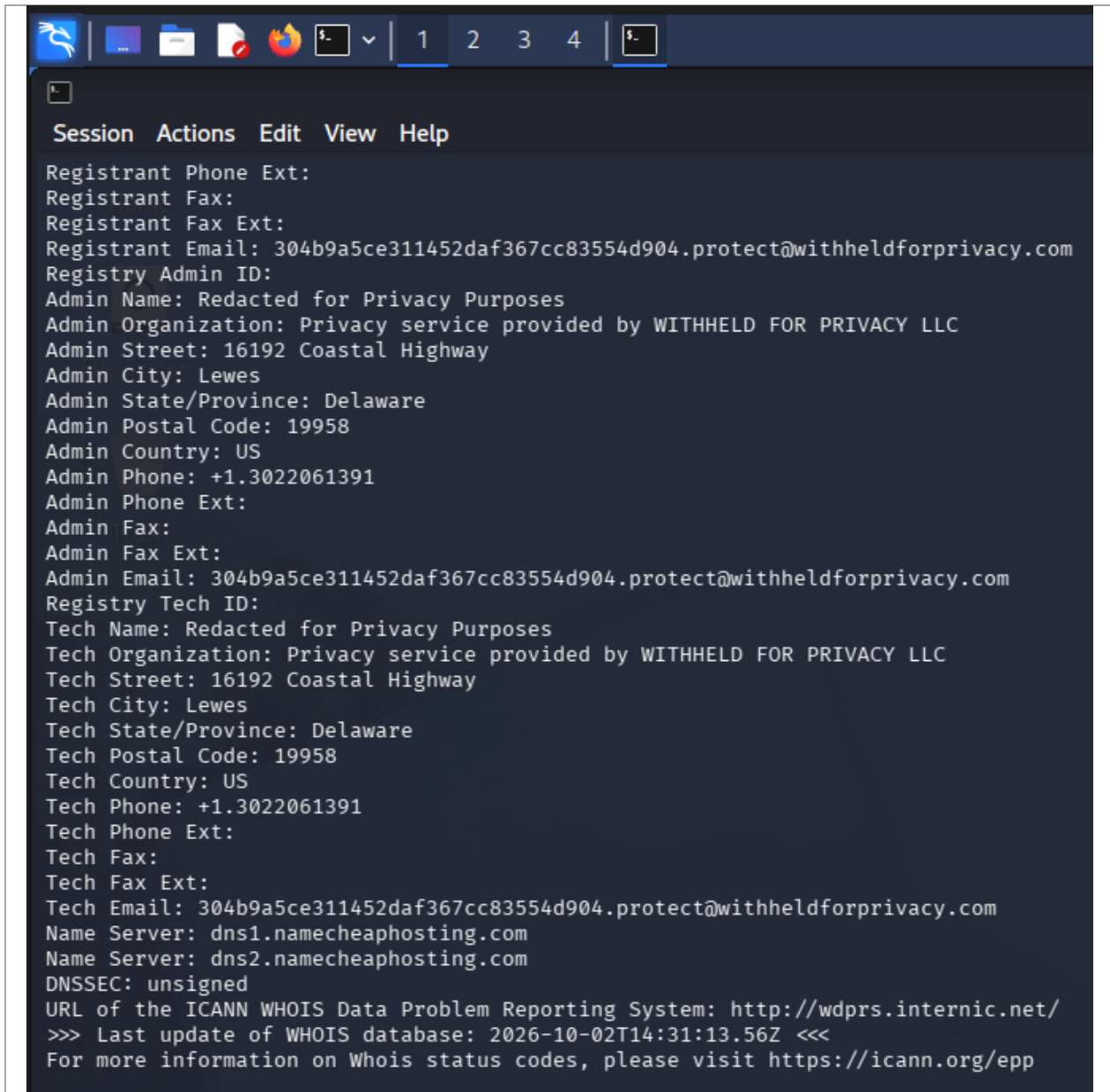
For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain name: medirozahospital.com
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 0001-01-01T00:00:00.00Z
Creation Date: 2026-08-14T20:51:24.00Z
Registrar Registration Expiration Date: 2027-08-14T20:51:24.00Z
Registrar: NAMECHEAP INC
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.9854014545
Reseller: NAMECHEAP INC
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registry Registrant ID:
Registrant Name: Redacted for Privacy Purposes
Registrant Organization: Privacy service provided by WITHHELD FOR PRIVACY LLC
Registrant Street: 16192 Coastal Highway
Registrant City: Lewes
Registrant State/Province: Delaware
Registrant Postal Code: 19958
Registrant Country: US
Registrant Phone: +1.3022061391
Registrant Phone Ext:
Registrant Fax:
Registrant Fax Ext:
```

Figure 1: WHOIS domain registration details



```

Session Actions Edit View Help
Registrant Phone Ext:
Registrant Fax:
Registrant Fax Ext:
Registrant Email: 304b9a5ce311452daf367cc83554d904.protect@withheldforprivacy.com
Registry Admin ID:
Admin Name: Redacted for Privacy Purposes
Admin Organization: Privacy service provided by WITHHELD FOR PRIVACY LLC
Admin Street: 16192 Coastal Highway
Admin City: Lewes
Admin State/Province: Delaware
Admin Postal Code: 19958
Admin Country: US
Admin Phone: +1.3022061391
Admin Phone Ext:
Admin Fax:
Admin Fax Ext:
Admin Email: 304b9a5ce311452daf367cc83554d904.protect@withheldforprivacy.com
Registry Tech ID:
Tech Name: Redacted for Privacy Purposes
Tech Organization: Privacy service provided by WITHHELD FOR PRIVACY LLC
Tech Street: 16192 Coastal Highway
Tech City: Lewes
Tech State/Province: Delaware
Tech Postal Code: 19958
Tech Country: US
Tech Phone: +1.3022061391
Tech Phone Ext:
Tech Fax:
Tech Fax Ext:
Tech Email: 304b9a5ce311452daf367cc83554d904.protect@withheldforprivacy.com
Name Server: dns1.namecheaphosting.com
Name Server: dns2.namecheaphosting.com
DNSSEC: unsigned
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
>>> Last update of WHOIS database: 2026-10-02T14:31:13.56Z <<<
For more information on Whois status codes, please visit https://icann.org/epp

```

Figure 2: WHOIS registrant/admin contact details (privacy-redacted)

nslookup resolved the domain to 199.188.201.16.

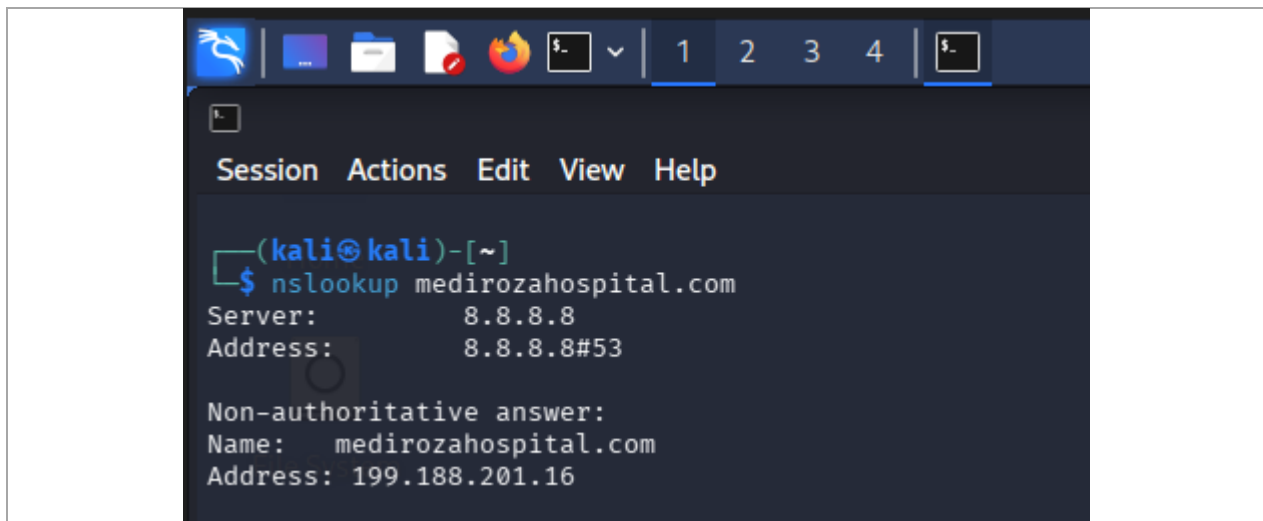


Figure 3: nslookup resolving medirozahospital.com

An **nmap** scan against that IP returned 11 open ports – considerably more than a single web server. Alongside the expected http/https, a full mail stack (pop3, imap, smtps, submission, imaps, pop3s) and an open FTP port (21) were also exposed. None of this was in scope to exploit further, but it materially increases the organisation's attack surface and is flagged as a finding in Section 5.

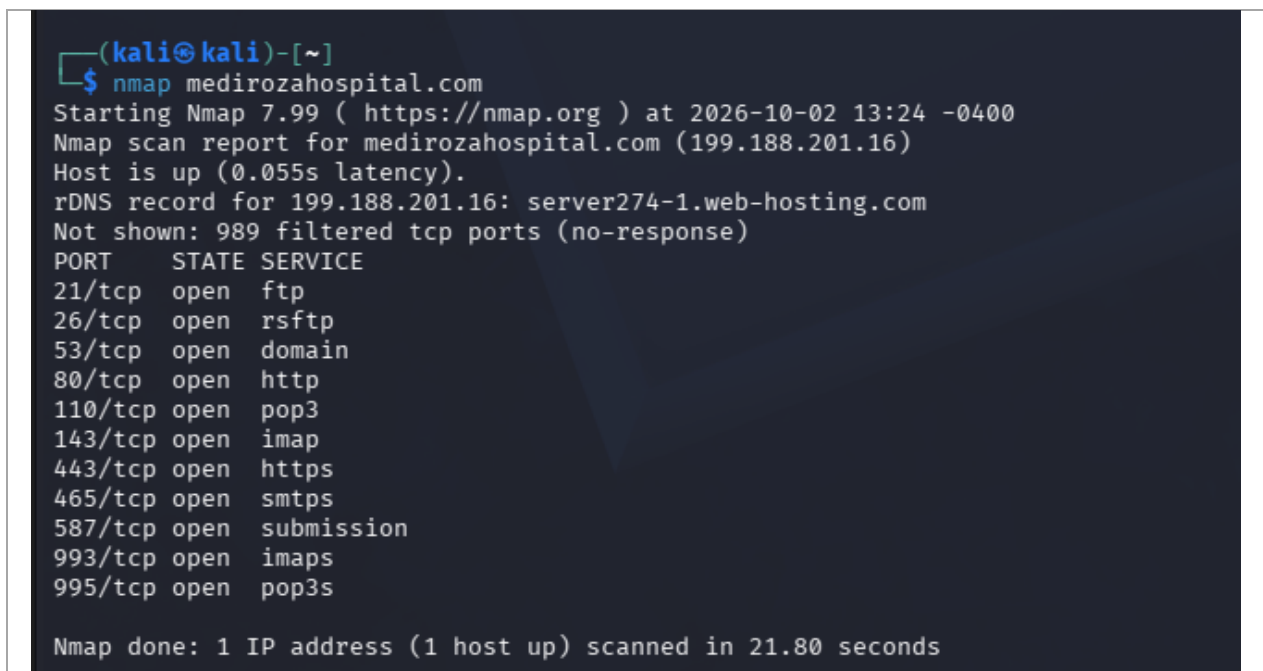


Figure 4: nmap port scan – 11 open ports identified

wafw00f confirmed the site sits behind a LiteSpeed WAF. This did not meaningfully affect testing, since no part of the attack chain required evading it.

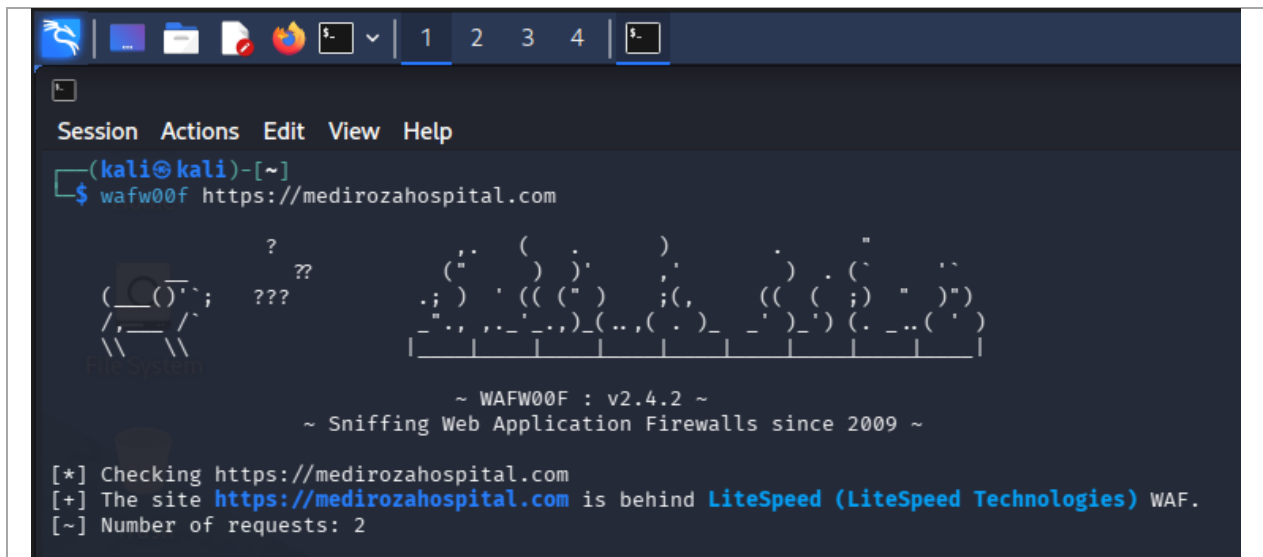
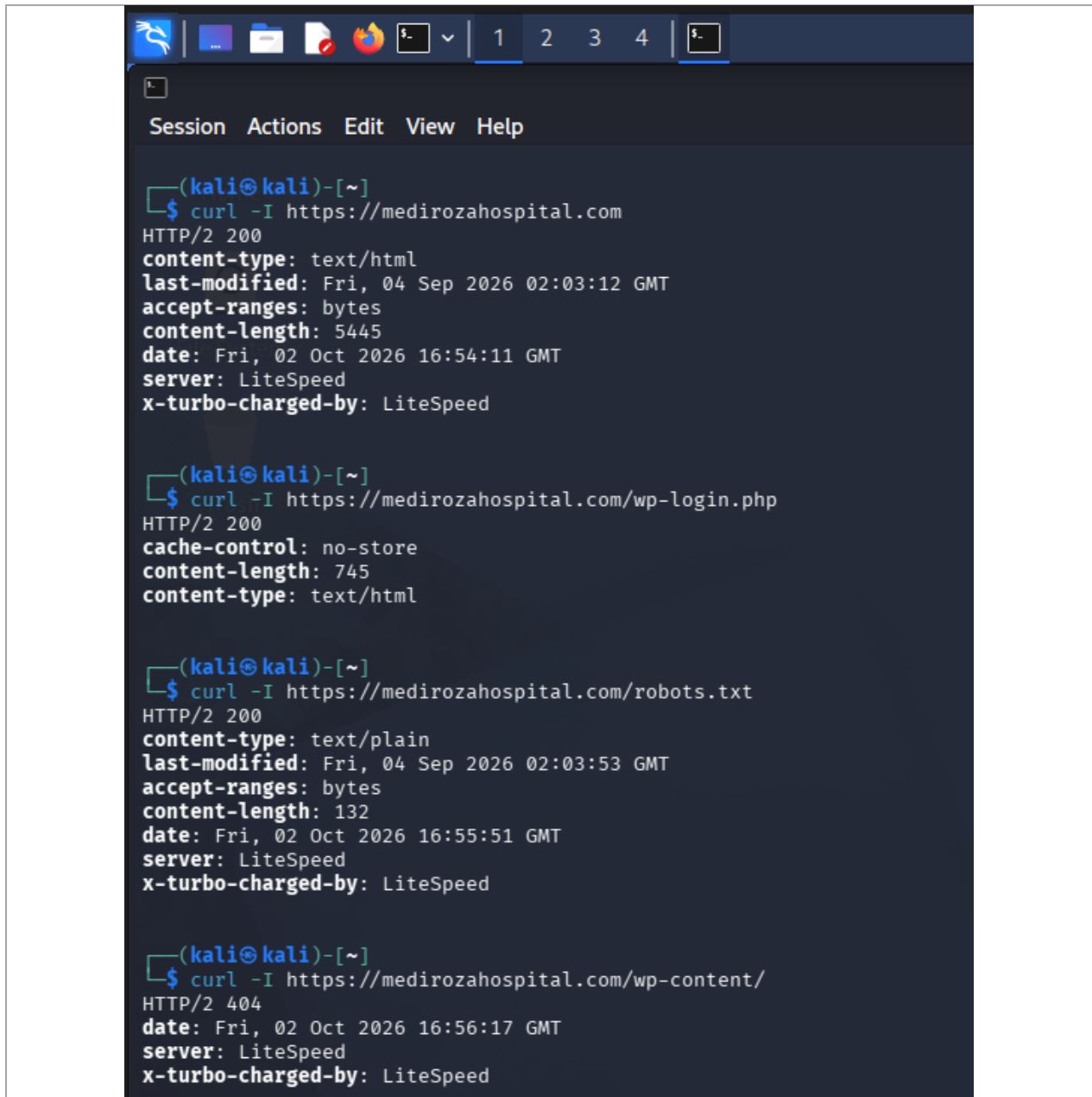


Figure 6: wafw00f identifying the LiteSpeed WAF

curl -I against a handful of likely paths confirmed robots.txt existed and was reachable (132 bytes, served as plain text). Reading it disclosed three paths that were clearly never meant to be advertised: /patient/, /staff/ and /old/. All three were directly accessible with no authentication in front of any of them. A secondary observation: /wp-content/ returned a 404, unusual for a WordPress installation and suggestive of an altered default structure.



```
(kali㉿kali)-[~]
$ curl -I https://medirozahospital.com
HTTP/2 200
content-type: text/html
last-modified: Fri, 04 Sep 2026 02:03:12 GMT
accept-ranges: bytes
content-length: 5445
date: Fri, 02 Oct 2026 16:54:11 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

(kali㉿kali)-[~]
$ curl -I https://medirozahospital.com/wp-login.php
HTTP/2 200
cache-control: no-store
content-length: 745
content-type: text/html

(kali㉿kali)-[~]
$ curl -I https://medirozahospital.com/robots.txt
HTTP/2 200
content-type: text/plain
last-modified: Fri, 04 Sep 2026 02:03:53 GMT
accept-ranges: bytes
content-length: 132
date: Fri, 02 Oct 2026 16:55:51 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed

(kali㉿kali)-[~]
$ curl -I https://medirozahospital.com/wp-content/
HTTP/2 404
date: Fri, 02 Oct 2026 16:56:17 GMT
server: LiteSpeed
x-turbo-charged-by: LiteSpeed
```

Figure 7: curl -I confirming robots.txt and probing further paths

/patient/ was found to have directory listing enabled, exposing the portal's full file structure along with its login form.

A closer look: the SQL injection

The login form took a username and password and, somewhere on the backend, clearly dropped both straight into a query without sanitising either. Rather than guessing at credentials, the first move was to test the input itself:

- Typed a single quote (') into the username field on its own and submitted the form. Instead of a clean "invalid login" message, the page threw back a database error – a strong sign the input was landing directly inside a raw SQL query instead of a parameterised one.
- That confirmed the query was shaped roughly like: `SELECT * FROM users WHERE username = '$username' AND password = '$password'`, with \$username and \$password substituted in from the form, unescaped.
- From there, the payload wrote itself: `admin'--` in the username field, with the password field left blank. The closing quote ends the string early, and `--` comments out everything after it, including the entire `AND password = '...'` check.
- The server logged the session in as admin. No valid password was ever typed, guessed, or needed – authentication wasn't bypassed so much as it was never actually enforced.

Inside the portal: three encrypted PDF lab reports – `patient_report_1.pdf`, `patient_report_2.pdf`, `patient_report_3.pdf` – exactly as the milestone required.

4.2 M2 – Data Extraction

Each PDF's hash was pulled with the NetworkWalks Hash Calculator and run through the Password Cracker's dictionary attack individually, treating each file as its own problem rather than assuming one approach would work for all three.

File	Password Recovered	Notes
<code>patient_report_1.pdf</code>	123456	Cracked on the first attempt, built-in wordlist
<code>patient_report_2.pdf</code>	password	Cracked on the second attempt, built-in wordlist
<code>patient_report_3.pdf</code>	!@#\$\$%^&	Needed the full wordlist of JTR Dedault Password match landed at attempt 3,546 of 3,556

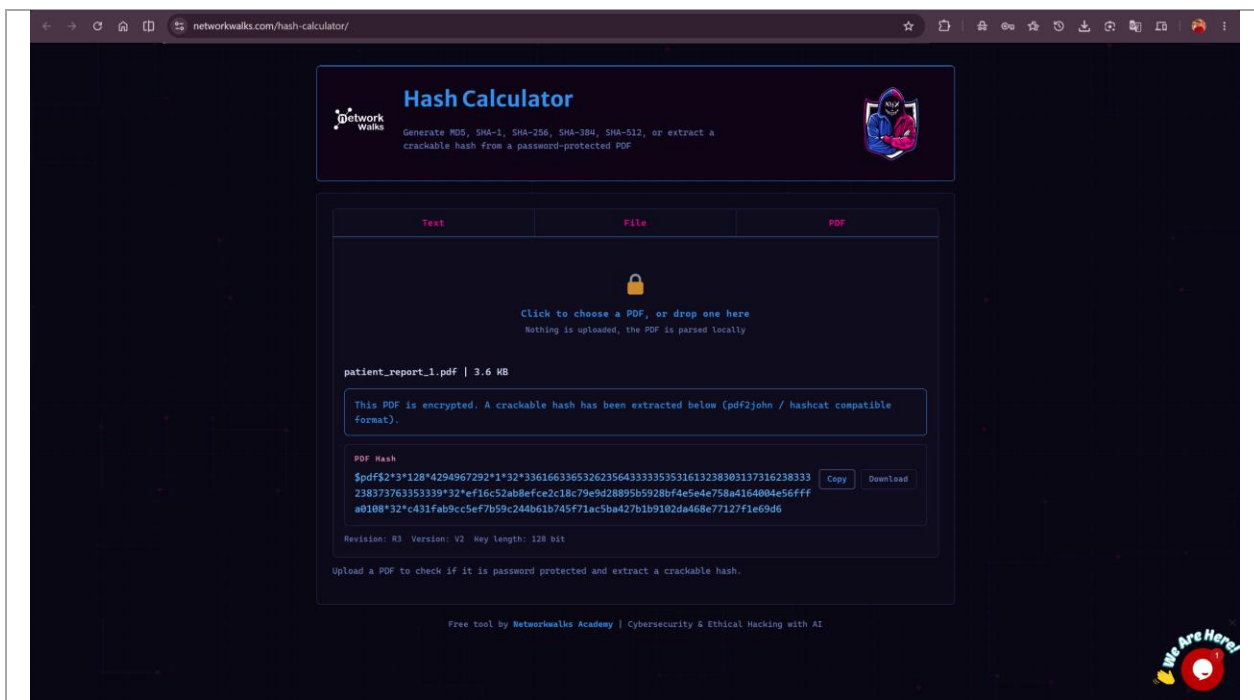


Figure 8: Hash Calculator extracting the hash for patient_report_1.pdf

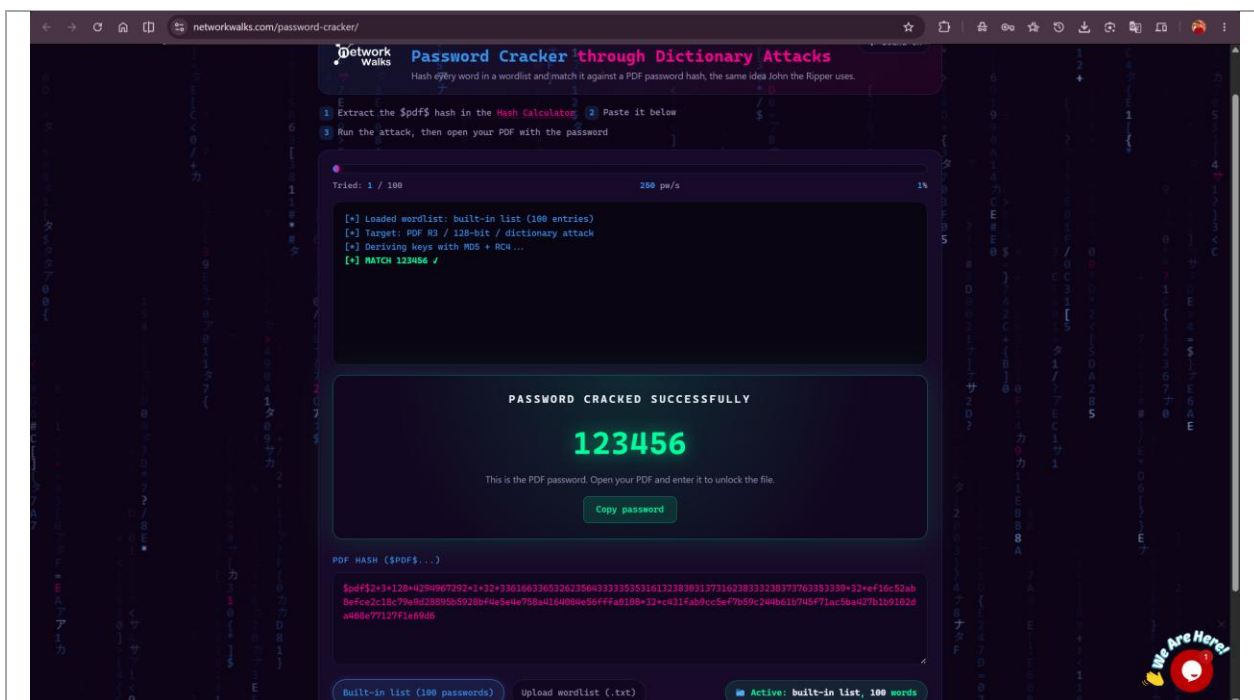


Figure 9: Password Cracker recovering 123456 for patient_report_1.pdf



Figure 10: patient_report_1.pdf opened with the recovered password

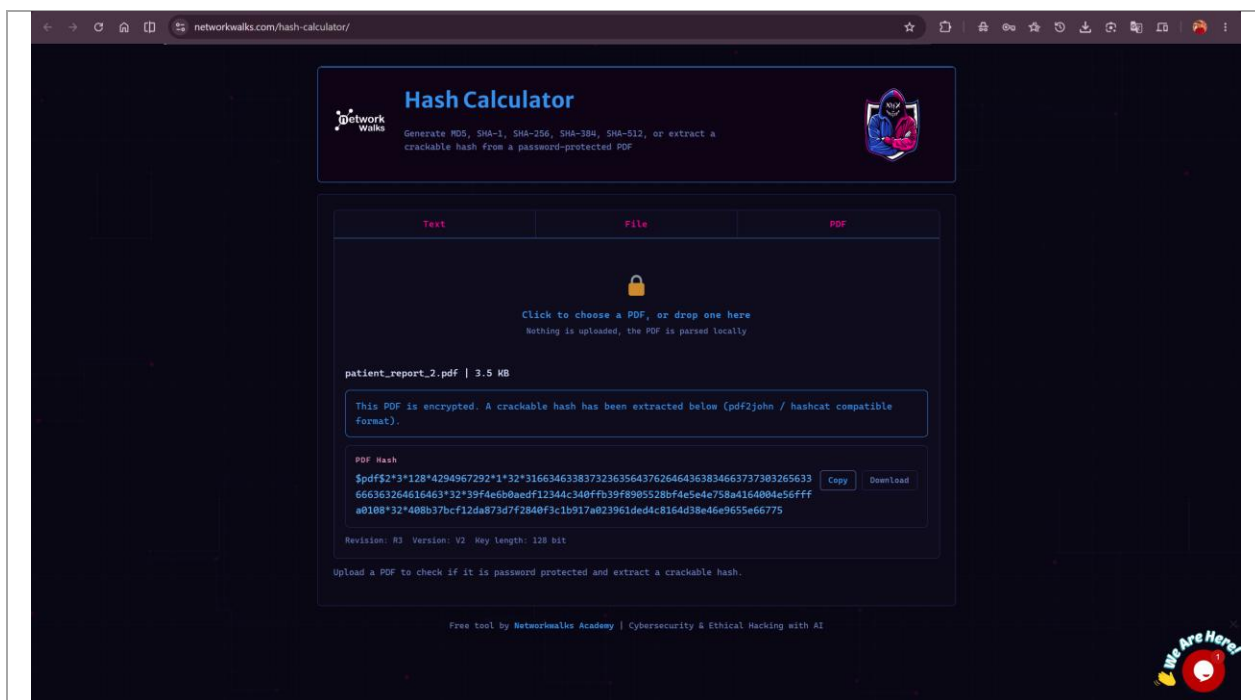


Figure 11: Hash Calculator extracting the hash for patient_report_2.pdf

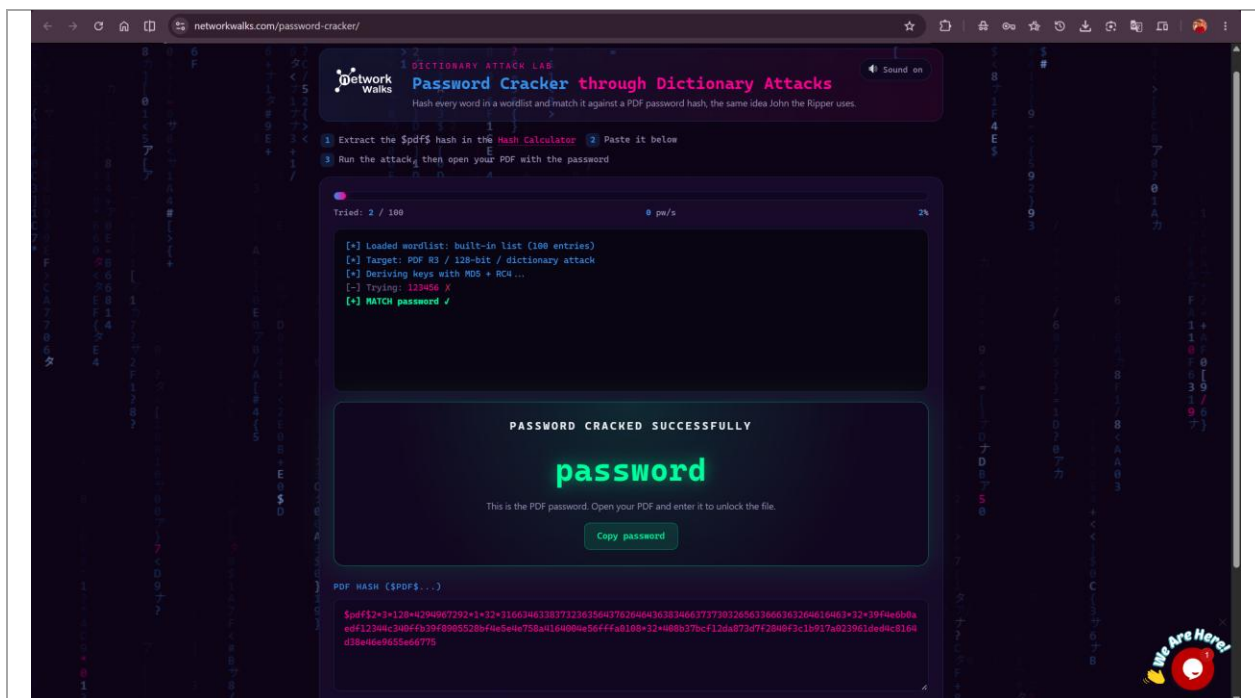


Figure 12: Password Cracker recovering “password” for patient_report_2.pdf

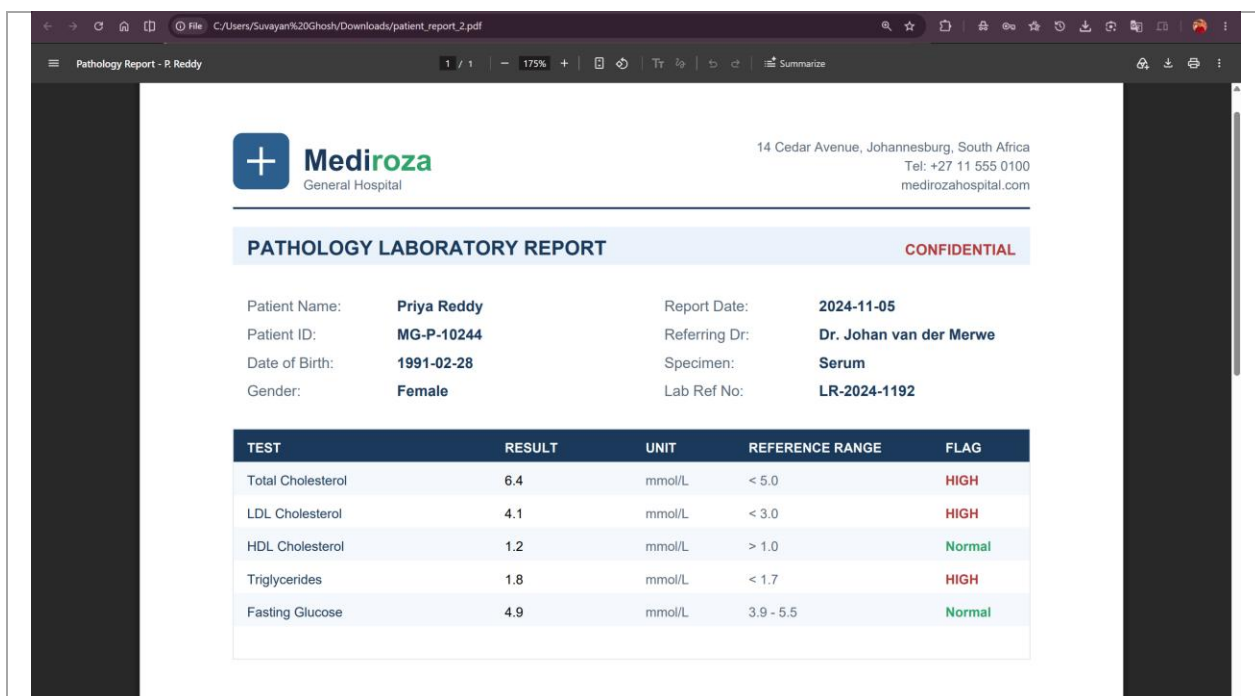


Figure 13: patient_report_2.pdf opened with the recovered password

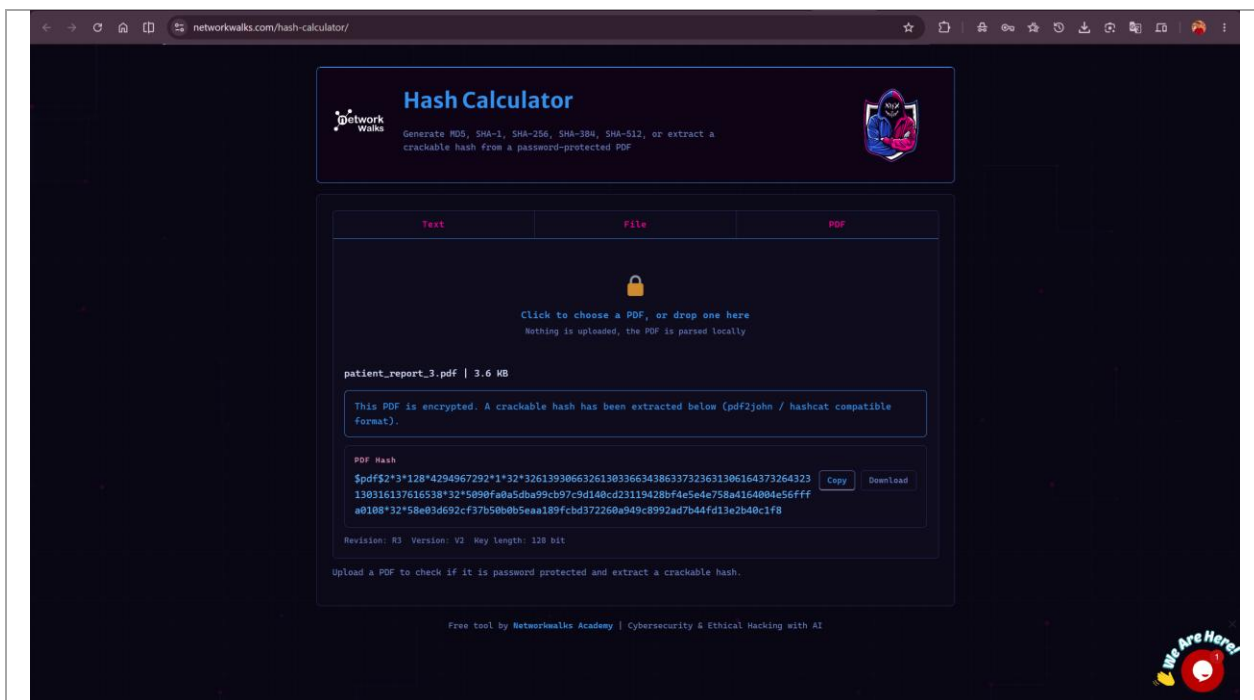


Figure 14: Hash Calculator extracting the hash for patient_report_3.pdf

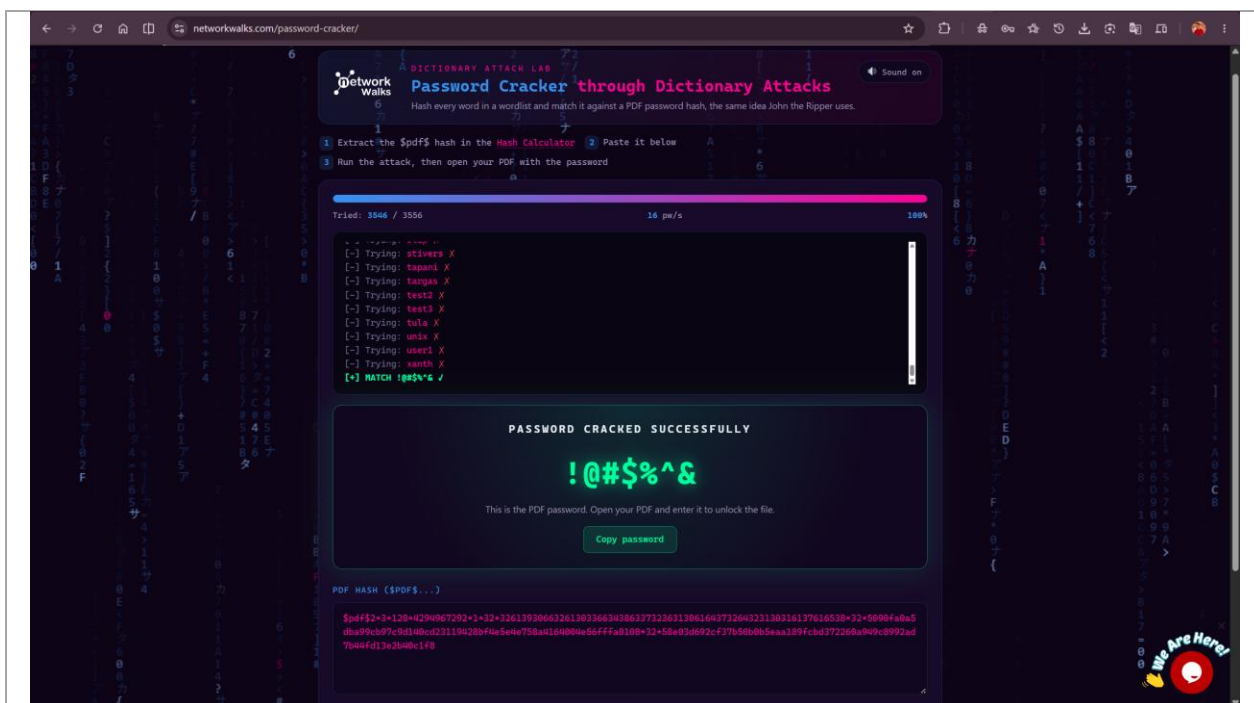


Figure 15: Password Cracker recovering !@#\$\$%^& for patient_report_3.pdf (3,546/3,556 attempts)

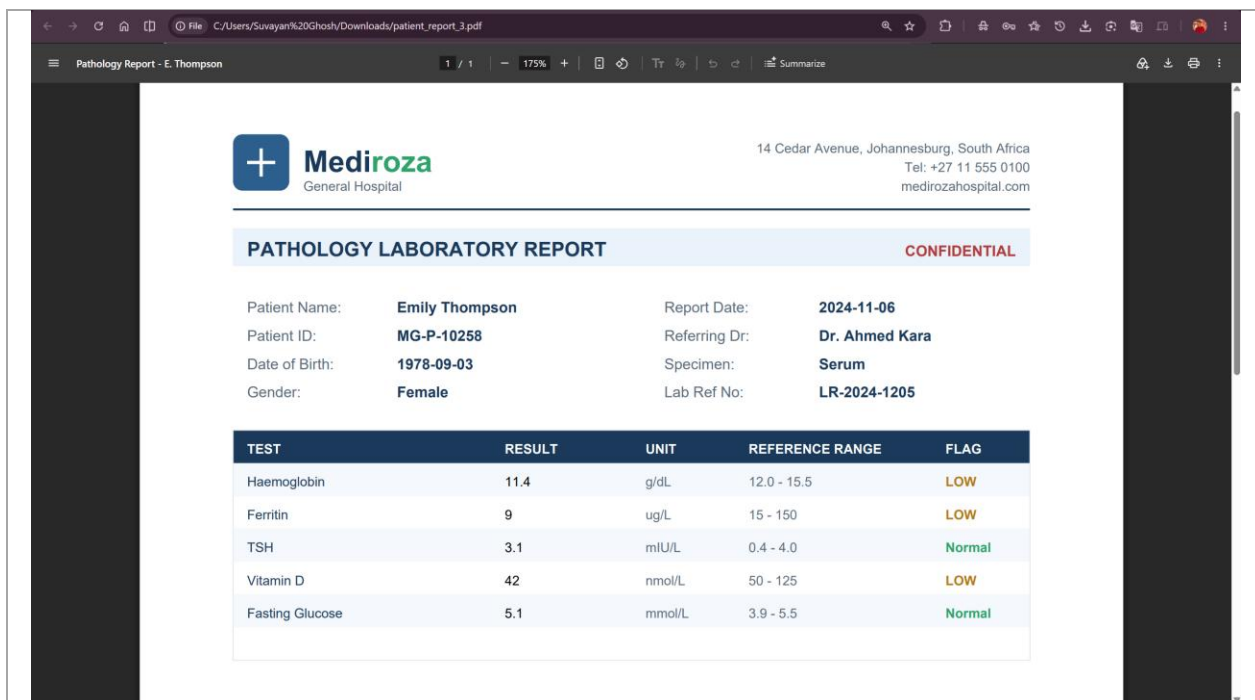


Figure 16: patient_report_3.pdf opened with the recovered password

The opened reports contain synthetic patient data created for this exercise (names, IDs and lab results) and are included here only as proof of successful decryption.

4.3 M3 – Critical Data Exposure

With all three files decrypted, the next step was reviewing everything already collected rather than treating “file decrypted” as the end of the milestone. Running exiftool against all three PDFs surfaced metadata on patient_report_3_decrypted.pdf that the visible content never would have: an internal comment reading “DB backup moved to /old before site migration, do not delete”, alongside an internal username, j.malik, left in the Author field.

```
(kali@kali)-[~/Downloads]
$ exiftool patient_report_3_decrypted.pdf
ExifTool Version Number      : 13.55
File Name                    : patient_report_3_decrypted.pdf
Directory                   : .
File Size                    : 2.9 kB
File Modification Date/Time  : 2026:10:01 03:30:43-04:00
File Access Date/Time       : 2026:10:01 03:30:55-04:00
File Inode Change Date/Time  : 2026:10:01 03:30:43-04:00
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension         : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : j.malik
Comments                     : DB backup moved to /old before site migration, do not delete
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                       : Pathology Report - E. Thompson
Page Count                   : 1
```

Figure 17: exiftool revealing the developer comment and username in PDF metadata

That comment pointed directly back to /old/ – one of the three paths robots.txt had already disclosed in M1, and still just as unauthenticated as the rest of the site. A directory listing there showed a single file, mediroza_db_backup_2019.sql, retrieved with curl. Its own header comments were explicit about what it contained: an internal database backup for the medroza_hr database, generated by the Mediroza CMS backup module, explicitly flagged by its own author as containing confidential staff and shareholder records.

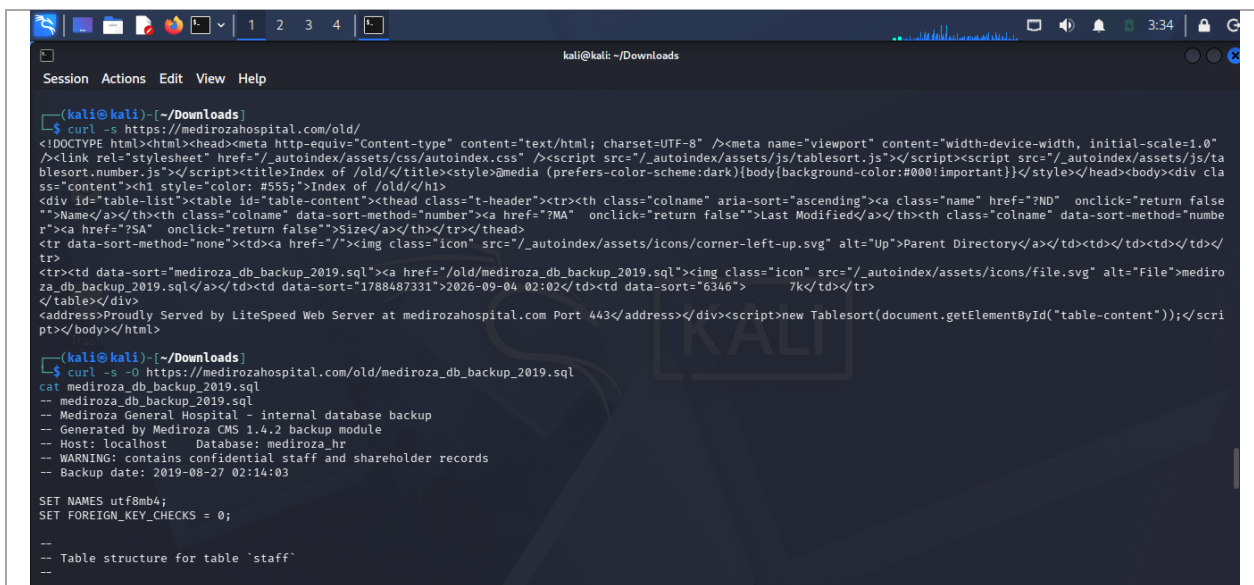


Figure 18: Directory listing on /old/ and retrieval of the database backup via curl

The backup's warning was not an exaggeration. The staff table alone contained full records for 30 employees – names, job titles, departments, email addresses, phone numbers, national ID numbers, and monthly salaries in ZAR openly readable in an unauthenticated SQL dump sitting on a live web server. The same backup file's own header comment confirms shareholder ownership records sit alongside the staff table within the full dump.



Figure 19: Leaked staff salary and personal data recovered from the database backup

Three milestones that looked unrelated on paper – a login bypass, a set of cracked PDF passwords, and a metadata review, turned out to be one continuous thread leading to this single exposure.

5. Risk Rating

Each finding identified during this engagement is rated below using a four-level scale (Critical, High, Medium, Low), based on the potential impact to Mediroza General Hospital and the likelihood of exploitation given what was observed.

#	Finding	Evidence / Observation	Potential Impact	Risk Level
1	SQL injection bypassing patient portal authentication	admin'-- in the login form returned an authenticated session with no valid credentials	Complete, unauthenticated access to the patient portal and everything behind it	● Critical
2	Unauthenticated, publicly exposed database backup	mediroza_db_backup_2019.sql retrieved directly from /old/ with no authentication	Full staff salary, national ID, and shareholder data exposed to anyone who finds the path	● Critical
3	Internal developer comment + username leaked via PDF metadata	exiftool revealed an author comment pointing to /old/ and an internal username	Directly enabled discovery of Finding 2; also exposes internal naming conventions	● High
4	Directory listing enabled on a sensitive path	/patient/ returned a full file index instead of a 403/404	Exposes application structure and file names to any visitor	● High
5	robots.txt disclosing unprotected, sensitive paths	/patient/, /staff/ and /old/ all listed in robots.txt and all directly reachable	Provides a ready-made map of sensitive areas to anyone who checks the file	● Medium
6	Dictionary-crackable PDF passwords	All three PDF passwords recovered via a small built-in or moderate-sized wordlist	Password protection on sensitive documents provided minimal real-world protection	● Medium
7	Non-web services exposed alongside the web app	nmap identified FTP (21) and a full mail stack open on the same host	Expands the attack surface beyond what this engagement's scope covered	● Low

Risk level key: ● Critical ● High ● Medium ● Low

6. Recommendations and Remediation

The following remediation steps are recommended, in priority order, to address the findings in Section 5:

1. **Eliminate the SQL injection** – Rebuild the patient portal login to use parameterised queries / prepared statements for all database access, validate and sanitise every user input server-side, and run a code review or static analysis pass across the application before redeployment.
2. **Remove the exposed database backup** – Delete /old/, /staff/ and /patient/ from the public web root immediately. Backups must never be stored inside a publicly reachable directory; store them outside the web root, encrypted at rest, with access restricted to authorised personnel only.
3. **Disable directory listing** – Turn off autoindexing across the web server for every directory, particularly any containing uploaded or sensitive files.
4. **Stop using robots.txt as an access control** – robots.txt is a disclosure risk when it lists sensitive paths. Remove references to non-public paths from it and enforce access control at the server/application layer instead.
5. **Strip metadata before distribution** – Run all client-facing PDFs through a metadata-sanitisation step (for example, `exiftool -all=`) before they are made available for download, and introduce a review step so internal comments and usernames are never left in production documents.
6. **Enforce a strong password policy** – None of the three recovered PDF passwords would withstand even a modest dictionary attack. Apply a minimum complexity and length standard across all password-protected materials, and consider proper access control in place of password-only PDF protection for sensitive documents.
7. **Reduce the exposed network surface** – Close FTP and any mail service ports that do not need to be publicly reachable, and review every other service nmap identified, not only the web application that was in scope for this engagement.
8. **Re-test after remediation** – Once the above fixes are implemented, a follow-up penetration test should confirm every finding in this report is fully resolved before the application is considered production-ready.

7. Conclusion

This capstone engagement moved beyond single-tool exercises into a full black-box penetration test, start to finish. What began as routine footprinting against `medirozahospital.com` ended up chaining a disclosed directory, a login form that trusted raw input, and a forgotten developer comment into complete, unauthenticated access to Mediroza General Hospital's staff salary and shareholder records.

No individual step in this chain was exotic. A robots.txt disclosure, an enabled directory listing, and an unsanitised login field are each the kind of finding that is easy to rate as minor in isolation – chained together, they handed over an entire backend. That is the central lesson of this engagement: small, individually-overlooked issues compound, and a thorough black-box

assessment has to follow every thread rather than stopping once the assigned milestone's literal requirement is technically met.

All findings, evidence and remediation guidance in this report are provided so that Mediroza General Hospital's engineering team can address the underlying issues directly. Networkwalks Academy and I remain available for any follow-up questions on this engagement.

-End of Report-

 Author

Suvayan Ghosh

Cybersecurity Analyst | Networkwalks Internship, Batch B083D

LinkedIn: <https://www.linkedin.com/in/suvayanghosh/>

 Project Information

Program: Cybersecurity & Ethical Hacking Internship at Networkwalks | Week 4 Capstone |
Milestones: M1–M4